

Windows 11 End-User Workstation VAPT Checklist

Scope: Authenticated/low-privilege internal assessment of domain-joined Windows 11 workstations

Methodology: Manual enumeration using native OS commands only (no scripts, exploit frameworks, or third-party tools on target) **Reporting basis:** CVSS v3.1 (use v4.0 in parallel if your client template requires it)

0. Pre-Engagement Notes

- Confirm rules of engagement explicitly cover credential use, lateral movement boundaries, and out-of-scope hosts
- Confirm whether passive observation of coercion primitives (e.g., forcing an auth attempt to a listener you control) is in scope, or whether enumeration must stop at "exposure identified, not exploited"
- Capture build number first — findings differ materially between 21H2/22H2/23H2/24H2 and current servicing state

```
systeminfo
winver
[Environment]::OSVersion
wmic os get Caption,Version,BuildNumber,OSArchitecture
```

1. Patch & Build Management

Check	Command	Notes
Installed updates / last patch date	<code>wmic qfe list brief / Get-HotFix</code>	Compare against current month's Patch Tuesday
Pending reboot for updates	<code>reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\WindowsUpdate\Auto Update\RebootRequired"</code>	
Feature		Workstations >2 feature

update lag (build vs. latest)	winver cross-ref with MS release health	updates behind = systemic finding
Third- party/driver patch state	Get-WmiObject Win32_Product (note: triggers MSI repair, use cautiously) or Get-Package	
WSUS/Intune compliance status	gpresult /r → check Update GPO source	

CVSS guidance: Severity should mirror the *highest unpatched CVE present*, not a flat “missing patches” rating. A workstation missing a patch for a known wormable RCE (e.g., historically MS17-010-class, PrintNightmare-class) scores against that CVE’s published base score, not a generic 5.0.

2. Authentication & Credential Exposure

- LSA Protection (RunAsPPL) enabled `reg query "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v RunAsPPL`
- WDigest disabled (plaintext creds in LSASS) `reg query "HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest" /v UseLogonCredential`
- Credential Guard status `Get-ComputerInfo -Property "DeviceGuard"`
- Cached domain credential count `reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v CachedLogonsCount`
- Local admin password uniqueness (LAPS deployed?) `reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\LAPS"`
- Stored credentials in Credential Manager `cmdkey /list`
- Saved RDP/VPN credentials on disk (check user profile, no extraction of contents)
- Autologon registry keys (plaintext password storage) `reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" /v DefaultPassword`
- Null session / anonymous SID enumeration restrictions `reg query "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v RestrictAnonymous`

Typical CVSS bands:

- Plaintext autologon password in registry: **High–Critical** (AV:L/AC:L/PR:L/UI:N/C:H) — direct credential disclosure
- WDigest enabled: **Medium–High**, contingent on LSASS access path

- Missing LAPS (shared local admin): **High** if confirmed shared across fleet (lateral movement amplifier)
-

3. NTLM / SMB / Network Authentication Coercion Surface

This is the category most relevant to your current focus — frame these as *exposure findings*, not exploitation proof, unless ROE explicitly authorizes triggering outbound auth to a listener.

- SMB signing enforcement (client and server) `reg query "HKLM\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters" /v RequireSecuritySignature`
- NTLM authentication level / restriction policy `reg query "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v LmCompatibilityLevel`
- Outbound NTLM restrictions to remote servers `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows\LanManWorkstation" /v RestrictSendingNTLMTraffic`
- LLMNR / NBT-NS still enabled (poisoning surface) `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient" /v EnableMulticast`
- WebClient (WebDAV) service running — required for several coercion chains `sc query webclient`
- Mail client patch state for CVE-2023-23397-class reminder/calendar coercion `wmic qfe list brief | findstr 5026370` (*adjust KB to current cumulative; confirm Outlook build separately via* `reg query "HKLM\SOFTWARE\Microsoft\Office\ClickToRun\Configuration" /v VersionToReport`)
- URI protocol handlers registered and resolvable (`ms-screensketch:`, `search-ms:`, etc.) — note presence is by design in Win11; the finding is the *combination* with outbound NTLM allowed + SMB signing absent, not the handler's existence alone
- Restriction of NTLM relay via EPA (Extended Protection for Authentication) on relevant services
- Local Security Authority NTLM audit logging enabled (for client detection capability, not just exposure)

Reporting framing: Score the *chain*, not the primitive in isolation. "NTLM coercion vector present" without SMB signing enforcement and without outbound NTLM blocking is the combination that produces a credible relay-to-domain-compromise path. A typical writeup:

Finding: Outbound NTLM authentication permitted to untrusted hosts combined with SMB signing not enforced on workstation tier. CVSS 3.1: AV:A/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N ≈ **8.0 (High)** — adjust AV/PR per your actual network position and account privilege during testing.

If signing is enforced and outbound NTLM is restricted, downgrade to **Low/Informational** even if a coercion primitive technically exists, since the relay path is broken.

4. RDP / Remote Access Configuration

- NLA (Network Level Authentication) enforced `reg query "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v UserAuthentication`
 - RDP encryption level `reg query "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v MinEncryptionLevel`
 - RestrictedAdmin mode availability
 - Session timeout / idle disconnect policy `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" /v MaxIdleTime`
 - RDP clipboard/drive redirection restrictions (data exfiltration path during low-priv session)
 - Concurrent session limits and remote desktop users group membership `net localgroup "Remote Desktop Users"`
-

5. Local Privilege Escalation Vectors

- Unquoted service paths `wmic service get name,displayname,pathname,startmode | findstr /i /v "C:\Windows"`
 - Weak service permissions (modify/restart rights for low-priv users) `accesschk -equivalent via native: sc qc <servicename> + manual ACL review with icaccls`
 - AlwaysInstallElevated MSI flag `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer" /v AlwaysInstallElevated reg query "HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer" /v AlwaysInstallElevated`
 - Writable PATH directories `echo %PATH% then icaccls each entry`
 - Scheduled tasks running as SYSTEM/admin with user-writable script targets `schtasks /query /fo LIST /v`
 - AutoRun registry entries and their target file permissions `reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" reg query "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run"`
 - UAC configuration (level, secure desktop, admin approval mode) `reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" /v ConsentPromptBehaviorAdmin`
-

6. Endpoint Protection & Detection Capability

- Defender real-time protection status and tamper protection `Get-MpComputerStatus`
 - Defender exclusions (paths/processes/extensions) — overly broad exclusions are a recurring finding
`Get-MpPreference | Select-Object ExclusionPath,ExclusionProcess,ExclusionExtension`
 - ASR (Attack Surface Reduction) rules enabled/audit-only `Get-MpPreference | Select-Object AttackSurfaceReductionRules_Ids,AttackSurfaceReductionRules_Actions`
 - Controlled Folder Access status
 - EDR agent presence and service health (if third-party EDR mandated by policy)
 - Windows Defender SmartScreen for apps/files `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows\System" /v EnableSmartScreen`
-

7. Application Control / Allowlisting

- AppLocker or WDAC policy presence and enforcement mode (enforced vs. audit) `Get-AppLockerPolicy -Effective`
 - PowerShell execution policy and Constrained Language Mode `Get-ExecutionPolicy -List $ExecutionContext.SessionState.LanguageMode`
 - PowerShell logging (ScriptBlock, Module, Transcription) enabled `reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging"`
 - Office macro policy (VBA blocked from internet-sourced files) `reg query "HKLM\SOFTWARE\Policies\Microsoft\Office\<version>\<app>\Security" /v VBAWarnings`
-

8. Data Protection & Encryption

- BitLocker status and protector type (TPM-only vs. TPM+PIN) `manage-bde -status`
 - TPM presence and version `Get-Tpm`
 - DMA protection / Kernel DMA Protection (Thunderbolt attack surface) `msinfo32` → Kernel DMA Protection field (manual GUI check)
 - Sensitive data in unencrypted locations (Downloads, Desktop) — sampling only, respect data-handling scope limits
-

9. Logging & Auditing

- Audit policy coverage (logon, process creation, object access) `auditpol /get /category:*`
- Command-line process auditing enabled (Event ID 4688 with command line) `reg query`

```
"HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\Audit" /v  
ProcessCreationIncludeCmdLine_Enabled
```

- Event log size/retention adequate to support incident response window `wevtutil gl Security`
 - Local event log access restricted from standard users (log tampering risk)
-

10. Removable Media & Physical

- USB storage restriction policy `reg query "HKLM\SYSTEM\CurrentControlSet\Services\USBSTOR" /v Start`
 - BadUSB-relevant Autoplay settings `reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer" /v NoDriveTypeAutoRun`
 - BIOS/UEFI password and boot order lock (where physical access in scope)
 - Secure Boot enabled `Confirm-SecureBootUEFI`
-

11. Browser & Mail Client Hardening

- Browser-managed policy enforcement (extensions allowlist, download restrictions)
 - Outlook protected view / attachment handling for untrusted senders
 - Autodiscover / SMB-based credential leak vectors via Office docs (linked-image UNC paths)
-

12. Baseline / Compliance Cross-Reference

- Run a manual delta against **CIS Microsoft Windows 11 Benchmark** (latest version) — prioritize Level 1 items for client-facing findings, note Level 2 separately as “defense-in-depth recommendations”
 - Cross-reference against current **Microsoft Security Compliance Toolkit** baseline for the workstation’s build
 - Document any compensating controls (e.g., network segmentation) that reduce real-world exploitability even where a setting deviates from baseline — this materially affects your CVSS Environmental score if your template includes one
-

CVSS Severity Banding Reference (for report writeup)

Score		
-------	--	--

Range	Rating	Typical workstation finding examples
9.0–10.0	Critical	Unpatched wormable RCE; plaintext domain admin creds recoverable; AlwaysInstallElevated + no AppLocker
7.0–8.9	High	NTLM relay chain viable (coercion + no signing + outbound NTLM allowed); LSA protection absent + WDigest enabled; shared local admin password fleet-wide
4.0–6.9	Medium	SMB signing not enforced but no confirmed relay target; verbose logging gaps; ASR rules in audit-only mode
0.1–3.9	Low	Minor baseline deviations with no credible exploitation path; informational misconfig with compensating controls present
0.0	Informational	Hardening recommendations beyond CIS Level 1; observations with no direct security impact

Scoring discipline for this engagement type:

- Always score the *demonstrated or credible* impact path, not the theoretical worst case of the primitive in isolation
- For chained findings (e.g., coercion + relay + privesc), either score the chain as one finding at the chain's severity, or score each link individually and cross-reference them in narrative — pick one convention and apply it consistently across the report
- Note in your methodology section that CVSS reflects technical severity only; banking-sector clients often want a secondary business-impact rating (e.g., data classification touched) alongside CVSS — confirm your report template's expectation before finalizing